

1. Executive Summary

Between 4 July 2026 and 5 July 2026, Greenfield assets experienced a Critical (P1) cyber security incident originating from a targeted initial compromise of workstation **GF-WS01**. A user executed a malicious HTML lure (`blog_lure.html`) disguised as a fake CloudLens login page. This launched an embedded launcher that initialized a PowerShell loader script (`loader.ps1`), which intentionally bypassed Windows Antimalware Scan Interface (AMSI). The loader fetched an encrypted second-stage payload over HTTP, decoded it in memory, allocated executable memory, and executed shellcode via `CreateThread` without writing the primary payload binary to disk.

Following initial execution, the attacker performed host, user, network, and Active Directory reconnaissance before leveraging network access to reach the file share `\GF-SRV01\Finance`, where a business invoice was accessed and copied. Static malware analysis identified tooling consistent with `RemCom/PsExec` (`psexec_service.exe`); however, available telemetry confirmed no malware execution or compromise on domain controller **GF-DC01**. No active persistence mechanisms or credential dumping were confirmed.

Current Status: GF-WS01 is isolated for containment and remediation. Priority actions include host reimaging, credential resets for targeted accounts, file access audit, and enhanced PowerShell logging deployment.

2. Incident Overview

Incident Reference	GF-INC-2026-0704
Investigation Window	2026-07-04 to 2026-07-05 (UTC)
Incident Severity	Critical (P1)
Incident Classification	Intrusion / Reflective Memory Execution / Unauthorized Share Access
Primary Detection Source	Microsoft Defender Alerts / KQL Telemetry Logs
Affected Assets	GF-WS01 (Confirmed Compromise) GF-SRV01 (Confirmed Access) GF-DC01 (Investigated - Clear)
Accounts Affected	sancadmin, svc_backup (Authentication activity reviewed)
Current Status	CONTAINED / PENDING REIMAGE
Lead Analyst / Team	DFIR Lead / Incident Response Team

3. Investigation Scope and Data Sources

In Scope: Workstations and servers **GF-WS01**, **GF-SRV01**, and **GF-DC01** examined during the period of 4–5 July 2026. Objective was to reconstruct initial infection, execution chain, persistence, lateral movement, and data collection.

Data Sources Evaluated:

- Microsoft Defender Telemetry:** Alert exports, device investigation timelines, and threat detection logs.
- KQL SIEM Queries:** Tables `DeviceProcessEvents`, `DeviceFileEvents`, `DeviceNetworkEvents`, `SecurityAlert`, `WindowsProcess_CL`, and `WindowsAuth_CL`.

- **Static Malware Analysis:** Artefacts analyzed via 7-Zip, Strings, objdump, and SHA256 checksum verification.

Investigation Limitations & Telemetry Gaps

Endpoint process ancestry (parent-child hierarchy) was partially unavailable in the telemetry datasets, limiting later-stage objective confidence to *Moderate*. Although PowerShell-Compress alerts and svc_backup authentications were recorded on GF-DC01, no corroborating process or payload execution events were observed on the Domain Controller.

4. Timeline of Events

TIME (UTC)	HOST	ACCOUNT	EVENT DESCRIPTION	MITRE	DATA SOURCE
2026-07-04 [Inf]	GF-WS01	User	Execution of malicious HTML lure blog_lure.html	T1204.001	File Artefact
2026-07-04 [Inf]	GF-WS01	User	Embedded HTML launcher launched loader.ps1	T1059.001	blog_lure.html
2026-07-04 [Inf]	GF-WS01	User / SYSTEM	AMSI bypass performed via AmsiUtils / amsiInitFailed	T1562.001	loader.ps1 Static
2026-07-04 [Inf]	GF-WS01	User	Encrypted payload fetched over HTTP & XOR decoded	T1105 / T1140	loader.ps1 Static
2026-07-04 [Inf]	GF-WS01	User	Shellcode executed in memory via VirtualAlloc / CreateThread	T1620	loader.ps1 Static
2026-07-04 [Inf]	GF-WS01	sancadmin	Reconnaissance commands executed (systeminfo, whoami, Get-ADUser)	T1082 / T1087	DeviceProcessEvents
2026-07-04 [Inf]	GF-SRV01	sancadmin	Finance share (\GF-SRV01\Finance) accessed; invoice document copied	T1039 / T1021	DeviceFileEvents
2026-07-04 [Inf]	GF-DC01	svc_backup	Defender alert generated; no endpoint malware execution confirmed	T1059.001	SecurityAlert
2026-07-05 [Inf]	Estate	IR Team	P1 Incident declared; containment and host isolation initiated	N/A	IR Operations

5. Technical Findings

High-Level Attack Chain Summary:

blog_lure.html (Lure) → loader.ps1 (AMSI Bypass) → In-Memory Shellcode Execution → System Reconnaissance → \GF-SRV01\Finance Access

5.1 Initial Access & Delivery

The initial infection vector was established on **GF-WS01** via user execution of blog_lure.html. Analysis confirmed this file rendered a fake CloudLens login UI with an embedded launcher that invoked an external PowerShell download command for loader.ps1. **Confidence: High**

5.2 Execution & Defence Evasion

Execution proceeded entirely within memory without dropping payload binaries to disk. The script loader.ps1 disabled AMSI by patching AmsiUtils.AmsiInitFailed before downloading an XOR-encrypted payload over HTTP. It allocated executable memory using VirtualAlloc, copied shellcode via Marshal.Copy, and created an execution thread via Win32 CreateThread. **Confidence: High**

5.3 Reconnaissance (Discovery)

The attacker executed host and Active Directory reconnaissance commands from GF-WS01, including: systeminfo, whoami, quser, hostname, ipconfig /all, arp -a, net view, net localgroup, net user sancadmin /domain, and Get-ADUser svc_backup. **Confidence: High**

5.4 Credential Access & Lateral Movement

Review of LSASS process activity showed no evidence of credential dumping tools (e.g., Mimikatz, ProcDump). Analysis of recovered binary psexec_service.exe (RemCom implementation) revealed it was located exclusively on the analyst workstation; no execution telemetry was detected on GF-WS01, GF-SRV01, or GF-DC01. **Confidence: Moderate**

5.5 Collection & Exfiltration

The attacker accessed the network share \GF-SRV01\Finance and copied an invoice document. While collection was confirmed, telemetry showed no evidence of compressed archive exfiltration outside the perimeter. **Confidence: Moderate**

6. MITRE ATT&CK Mapping

TACTIC	TECHNIQUE ID	TECHNIQUE NAME	EVIDENCE / TECHNICAL REFERENCE
Initial Access	T1204.001	User Execution: Malicious Link / File	User launched blog_lure.html
Execution	T1059.001	Command and Scripting Interpreter: PowerShell	Execution of loader.ps1
Execution / Evasion	T1620	Reflective Code Loading	In-memory shellcode execution via Win32 CreateThread
Defense Evasion	T1562.001	Impair Defenses: Disable or Modify Tools	Disabled AMSI via AmsiUtils manipulation
Discovery	T1082 / T1087	System Information / Account Discovery	Recon commands (systeminfo, whoami, Get-ADUser)
Lateral Movement	T1021.002	Remote Services: SMB/Windows Admin Shares	Accessed network file share \GF-SRV01\Finance
Collection	T1039	Data from Network Shared Drive	Invoice document copied from Finance share

7. Impact Assessment & Root Cause

Operational Impact: One workstation (GF-WS01) compromised; one file share (GF-SRV01 Finance) accessed with business invoice data collected. No active persistence, domain controller compromise, or mass exfiltration was detected.

Root Cause Identification

The incident was made possible by **unrestricted execution of unverified local HTML files** combined with **permissive local PowerShell execution policies**. This allowed an unauthenticated script to disable AMSI protections and load shellcode directly into memory without triggering endpoint preventative blocks.

9. Indicators of Compromise (IoCs)

INDICATOR TYPE	INDICATOR VALUE / NAME	DESCRIPTION & CONTEXT
File Artefact	blog_lure.html	Social engineering HTML lure displaying fake login UI
File Artefact	loader.ps1	PowerShell script performing AMSI bypass & in-memory loader
File Artefact	gfupdater.exe	Native C++ payload with HTTP connector & named pipe support
File Artefact	psexec_service.exe	RemCom service wrapper binary recovered during investigation
Network Share	\GF-SRV01\Finance	Targeted SMB file share accessed by threat actor
User Account	sancadmin / svc_backup	Targeted domain accounts subjected to enumeration/auth review

10. Remediation & Recommendations

PRIORITY	ACTION ITEM	TECHNICAL RATIONALE	STATUS
P1	Isolate and reimage workstation GF-WS01	Completely eliminate in-memory shellcode artifacts	Recommended
P1	Reset credentials for sancadmin and svc_backup	Mitigate risk from account enumeration during discovery	Recommended
P2	Enforce PowerShell Constrained Language Mode & WDAC	Prevent execution of unverified scripts and AMSI bypasses	Recommended
P2	Enable Script Block Logging (Event ID 4104)	Provide visibility into obfuscated or memory-loaded scripts	Recommended
P3	Apply least-privilege SMB access on \GF-SRV01\Finance	Restrict unauthorized network share enumeration	Recommended

11. Appendix: KQL Detection Rules

Detections developed from incident telemetry for deployment in Microsoft Sentinel / Defender:

```
// Detection 1: AMSI Bypass Pattern in PowerShell Commands
DeviceProcessEvents
| where ProcessCommandLine has_any ("AmsiUtils", "amsiInitFailed")
| project Timestamp, DeviceName, AccountName, ProcessCommandLine, InitiatingProcessFileName

// Detection 2: Suspicious Interactive PowerShell Shellcode API Invocations
DeviceProcessEvents
| where FileName in~ ("powershell.exe", "pwsh.exe")
| where ProcessCommandLine has_any ("VirtualAlloc", "CreateThread", "Marshal.Copy")
| project Timestamp, DeviceName, AccountName, ProcessCommandLine
```

LOG(N) Pacific Cyber Range — Greenfield Simulated Incident Assessment — Ref: GF-INC-2026-0704